

Linux'ta Kullanıcılar, İzinler, Süreçler ve En Az Yetki

cat /etc/passwd → Komut, Linux'taki kullanıcı hesap bilgilerinin bulunduğu dosyanın içeriğinin görüntülenmesini sağlar.

```
vboxuser@Ubuntu:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailng List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:996:996:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
messagebus:x:995:995:System Message Bus:/nonexistent:/usr/sbin/nologin
```

cat /etc/group → Komut, Linux'taki grup bilgilerinin tutulduğu dosyadır.

```
vboxuser@Ubuntu:~$ cat /etc/group
root:x:0:
daemon:x:1:
bin:x:2:
sys:x:3:
adm:x:4:syslog,vboxuser
tty:x:5:
disk:x:6:
lp:x:7:
mail:x:8:
news:x:9:
uucp:x:10:
man:x:12:
proxy:x:13:
kmem:x:15:
dialout:x:20:
fax:x:21:
voice:x:22:
cdrom:x:24:vboxuser
floppy:x:25:
tape:x:26:
sudo:x:27:vboxuser
audio:x:29:
dip:x:30:vboxuser
www-data:x:33:
```

sudo → Linux'ta bir komutu geçici olarak daha yüksek yetkiyle çalıştırmak için kullanılır.

sudo cat /etc/shadow → /etc/shadow normal kullanıcıların okuyamadığı, hassas bir dosya olduğu için sudo ile yetki yükselterek kullanılır. Bu içerikte hashlenmiş parolalar görüntülenebilir.

- Bir kullanıcıya sudo yetkisi verilmesi, o kullanıcının yönetici seviyesinde işlemler gerçekleştirebilmesini sağlar. Bu nedenle SOC analisti, özellikle kimlerin sudo yetkisine sahip olduğunu ve sudo ile hangi komutları çalıştırabildiğini kontrol eder.

touch test.txt → Linux'ta test.txt adında yeni ve boş bir dosya oluşturur. Dosya zaten varsa, dosyanın erişim/değiştirilme zaman bilgilerini (timestamps) güncelleyebilir.

ls -l test.txt → Dosya izinlerinin okunmasını sağlar.

-rw-rw-r-- → Aldığımız bu çıktıyı -rw- | rw- | r-- olarak üçe ayırıyoruz:

İlk bölüm dosyanın sahibi(owner)

İkinci bölüm grup

Üçüncü bölüm diğer kullanıcılar(others)

Harflerin anlamları:

r → Read → 4
w → Write → 2
x → Execute → 1
- → İzin yok → 0

Yani çıktısını almış olduğum -rw-rw-r-- için

-rw- | rw- | r-- → rw- = 4+2+0= 6 ; r-- = 4

Bu dosyanın izinleri : 664

```
vboxuser@Ubuntu:~/test-file$ touch test.txt
vboxuser@Ubuntu:~/test-file$ ls -l test.txt
-rw-rw-r-- 1 vboxuser vboxuser 0 Aug 10 07:35 test.txt
vboxuser@Ubuntu:~/test-file$ chmod 600 test.txt
vboxuser@Ubuntu:~/test-file$ ls -l test.txt
-rw----- 1 vboxuser vboxuser 0 Aug 10 07:35 test.txt
```

chmod → Dosya izinlerini değiştirir.

chown → Dosyanın owner ını değiştirir.

umask → Yeni oluşturduğum dosyaların başlangıçta hangi izinlere sahip olacağını belirleyen ayardır.

/etc/sudoers → sudo kullanılabilir mi, neler çalıştırılabilir yetkilendirmesinin belirlendiği dosyadır.

UID Nedir? User ID. Linux kullanıcıları isimleriyle değil, sistem içerisinde aslında sayısal bir kimlikle tanır.

GID Nedir? Group ID. Grupların da Linux içerisinde sayısal kimliği vardır.

- Linux daki en önemli kullanıcı : root.
- Root un UID'si : 0
- Root sistem üzerinde çok geniş yetkilere sahiptir.
- Bir SOC analisti açısından, bir sistemde beklenmeyen şekilde UID 0 yetkisine sahip bir kullanıcı görülmesi ciddi şekilde incelenir.

SUID Nedir? Set User ID. Program, çalıştıran kullanıcının değil, dosyanın sahibinin yetkileriyle çalışır.

SUID izni dosya izinlerinde s karakteriyle görülür. Sistemde SUID dosyalarını listelemek için:

find / -perm -4000 -type f 2>/dev/null

-perm -4000 → SUID biti ayarlanmış dosyaları ara.

2>/dev/null → Hata mesajlarını ekranda gösterme.

SUID tek başına güvenlik açığı değildir; ancak gereksiz veya güvenli olmayan bir SUID programı, saldırgan tarafından yetki yükseltme amacıyla kullanılabileceğinden analiz edilmesi önemlidir.

SOC analisti açısından bu komutun amacı sistemde hangi programların SUID yetkisine sahip olduğunu tespit etmek.

SUID listesinin kısa olması, sistemde bir sorun olduğu anlamına gelmez. Tam tersine, SUID'in sınırlı kullanılması güvenlik açısından tercih edilir.

SGID Nedir? Programı dosyanın grubunun yetkisiyle çalıştırır / klasörde grubu miras aldırır.

SGID verilmişse, developers grubundaki farklı kullanıcıların oluşturduğu dosyalar otomatik olarak developers grubuna ait olur.

Bu, ekiplerin ortak dosyalar üzerinde çalışmasını kolaylaştırır.

SGID, dosya ve klasörlerde grup tabanlı erişimi etkilediği için yetki analizinde önemlidir. Özellikle beklenmeyen bir SGID dosyası veya yanlış yapılandırılmış ortak klasör, yetki kontrolü açısından incelenebilir.

Sticky Bit → Ortak klasörde kullanıcıların başkasının dosyasını silmesini engeller.

Süreç Nedir?

Diskte duran bir program ile çalışan program aynı şey değildir. Örneğin; /usr/bin/firefox diskte bulunan bir program dosyasıdır. Ben Firefox'u açtığımda işletim sistemi bu programı belleğe yükler ve çalıştırır. Artık çalışan bir process oluşur.

Bir süreci tanımlamak için en önemli bilgilerden ikisi PID ve PPID'dir.

PID(Process ID) → Her çalışan sürece işletim sistemi tarafından verilen benzersiz süreç numarasıdır. Bir süreci sonlandırırken de genellikle PID kullanılır.

PPID(Parent Process ID) → Bir süreci başlatan üst sürecin PID'sidir. Child process, parent process'in PID'sini PPID olarak taşır.

PID + PPID birlikte incelendiğinde process ağacı ve bir process'in nasıl başlatıldığı anlaşılabilir.

ps → Bu komut mevcut terminal oturumuyla ilişkili süreçleri gösterir.

```
vboxuser@Ubuntu:~/test-file$ ps
  PID TTY          TIME CMD
  4486 pts/0    00:00:00 bash
  23612 pts/0    00:00:00 ps
```

PID Sütunu → Sürecin kimlik numarası

TTY → Sürecin bağlı olduğu terminal

TIME → CPU'da harcadığı işlem zamanı

CMD → Çalışan komut/program

ps aux → Çok daha geniş süreç listesi görüntülenebilir.

Sütunlar:

User → Süreci hangi kullanıcı çalıştırıyor?

PID → Sürecin kimlik no

%CPU → Sürecin CPU kullanım oranı

- Çok yüksek CPU kullanımı tek başına saldırı anlamına gelmez ama araştırılması gereken bir durum olabilir. -

%MEM → Sürecin RAM kullanım oranı.

STAT → Sürecin mevcut durumu.

COMMAND → Çalışan programın/komutun ne olduğunu gösterir.

ps -eo pid,ppid,user,stat,cmd → Komutuyla hangi sütunları görüntülemek istediğimi seçtim.

top → Linux sisteminde çalışan süreçleri anlık olarak izlemek için kullanılır. ps komutundan farklı olarak süreç bilgilerini sürekli günceller ve CPU ile bellek kullanımını takip etmeyi sağlar.

```
top - 13:17:56 up 5:58, 1 user, load average: 0.09, 0.27, 0.20
Tasks: 270 total, 1 running, 269 sleeping, 0 stopped, 0 zombie
%Cpu(s): 2.1 us, 2.0 sy, 0.0 ni, 95.5 id, 0.1 wa, 0.0 hi, 0.4 si, 0.0 st
MiB Mem : 3398.1 total, 124.5 free, 2517.5 used, 1071.4 buff/cache
MiB Swap: 0.0 total, 0.0 free, 0.0 used, 880.6 avail Mem
```

PID	USER	PR	NI	VIRT	RES	SHR	S	%CPU	%MEM	TIME+	COMMAND
3360	vboxuser	20	0	5194172	445952	116320	S	17.9	12.8	5:18.75	gnome-+
4439	vboxuser	20	0	2905700	310772	95672	S	7.6	8.9	1:46.30	ptxis
21714	vboxuser	20	0	11.5g	422888	87348	S	0.7	12.2	3:09.38	firefox
28259	vboxuser	20	0	2577496	70596	55460	S	0.7	2.0	0:00.66	Web Co+
15	root	20	0	0	0	0	I	0.3	0.0	0:14.05	rcu_pr+
1900	root	20	0	355748	2636	2352	S	0.3	0.1	1:01.45	VBoxDR+
3730	vboxuser	20	0	631712	18668	14604	S	0.3	0.5	0:02.63	xdg-de+
21899	vboxuser	20	0	2648996	106900	61864	S	0.3	3.1	0:27.56	Privil+
22445	vboxuser	20	0	3105724	437780	72052	S	0.3	12.6	1:35.73	Isolat+
23327	root	20	0	0	0	0	I	0.3	0.0	0:01.65	kwerke+
24951	root	20	0	0	0	0	I	0.3	0.0	0:01.82	kwerke+
27899	root	20	0	0	0	0	I	0.3	0.0	0:00.42	kwerke+
28063	vboxuser	20	0	2577496	70544	55556	S	0.3	2.0	0:00.83	Web Co+
28239	root	20	0	0	0	0	I	0.3	0.0	0:00.20	kwerke+
28302	vboxuser	20	0	13412	6324	4160	R	0.3	0.2	0:00.05	top
1	root	20	0	26388	16528	10812	S	0.0	0.5	0:11.58	systemd
2	root	20	0	0	0	0	S	0.0	0.0	0:00.29	kthrea+

P tuşu süreçleri CPU kullanımına, M tuşu ise bellek kullanımına göre sıralar.

Analist açısından; top, yüksek CPU/bellek kullanan veya beklenmeyen kullanıcı tarafından çalıştırılan süreçleri hızlı şekilde fark etmek ve incelemeye başlamak için kullanılır. Yüksek kaynak kullanımı tek başına zararlı faaliyet anlamına gelmez; süreç, kullanıcı ve çalışma amacı birlikte değerlendirilmelidir.

Servis Nedir? Linux'ta sistem arka planında belirli bir işi sürekli veya gerektiğinde gerçekleştiren programdır.

Servis → Programın sistemdeki görevi/yönetilen hizmeti

Process → O anda çalışan programın süreç örneği

systemctl → Linux'ta özellikle systemd tarafından yönetilen servisleri kontrol etmek için kullanılan komuttur. Servis çalışıyor mu, duruyor mu, başlatılsın mı, kapatılsın mı? Ubuntu'da çalışan Nginx bu servislere örnektir.

Nginx'in durumunu kontrol etmek için → systemctl status nginx

```
vboxuser@Ubuntu:~/test-file$ systemctl status nginx
● nginx.service - A high performance web server and a reverse proxy server
   Loaded: loaded (/usr/lib/systemd/system/nginx.service; enabled; preset: en>
   Active: active (running) since Mon 2026-08-10 12:25:56 UTC; 52min ago
     Invocation: a064d327e57246adafb8ff5abf330308
       Docs: man:nginx(8)
    Process: 25793 ExecStartPre=/usr/sbin/nginx -t -q -g daemon on; master_pro>
    Process: 25798 ExecStart=/usr/sbin/nginx -g daemon on; master_process on; >
   Main PID: 25801 (nginx)
      Tasks: 5 (limit: 1856)
     Memory: 4.6M (peak: 5.5M)
        CPU: 41ms
      CGroup: /system.slice/nginx.service
              └─25801 "nginx: master process /usr/sbin/nginx -g daemon on; mast>
                 └─25802 "nginx: worker process"
                    └─25803 "nginx: worker process"
                       └─25804 "nginx: worker process"
                          └─25805 "nginx: worker process"

Aug 10 12:25:55 Ubuntu systemd[1]: Starting nginx.service - A high performance>
Aug 10 12:25:56 Ubuntu systemd[1]: Started nginx.service - A high performance >
```

Temel servis komutları:

sudo systemctl start nginx → Servisi başlatır
sudo systemctl stop nginx → Servisi durdurur
sudo systemctl enable nginx → Açılışta otomatik başlatır
sudo systemctl disable nginx → Açılışta otomatik başlatmayı kaldırır

Yapılandırma dosyaları değiştiğinde sudo systemctl daemon-reload ile systemd'nin servis yapılandırmasını yeniden okuması sağlanır.

Analist açısından; bir servisin çalışıp çalışmadığı, sistem açılışında otomatik başlatılıp başlatılmadığı ve sistemde gerçekten gerekli olup olmadığı kontrol edilmelidir. Beklenmeyen veya gereksiz bir servis, sistem güvenliği açısından incelenmesi gereken bir durum olabilir.

```
vboxuser@Ubuntu:~/test-file$ ps -ef | grep nginx
root      25801      1    0 12:25 ?        00:00:00 nginx: master process /usr/
sbin/nginx -g daemon on; master_process on;
www-data  25802    25801    0 12:25 ?        00:00:00 nginx: worker process
www-data  25803    25801    0 12:25 ?        00:00:00 nginx: worker process
www-data  25804    25801    0 12:25 ?        00:00:00 nginx: worker process
www-data  25805    25801    0 12:25 ?        00:00:00 nginx: worker process
vboxuser  28429    4486    0 13:19 pts/0    00:00:00 grep --color=auto nginx
```

Süreçlerin Normal / Anormal Değerlendirilmesi

Bir sürecin normal veya şüpheli olduğunu değerlendirirken yalnızca adına bakılmaz. Sürecin hangi kullanıcı tarafından çalıştırıldığı, PID ve PPID ilişkisi, çalıştırıldığı dosya yolu, CPU/RAM kullanımı ve sistemde çalışmasının gerekli olup olmadığı birlikte değerlendirilir.

Örneğin Nginx'in web sunucusu olarak kullanılan bir Ubuntu makinesinde çalışması normaldir. Ancak beklenmeyen bir programın root yetkisiyle veya /tmp gibi alışılmadık bir konumdan çalışması inceleme gerektirebilir.

Analist açısından: Amaç tek bir belirtiye bakarak süreci zararlı ilan etmek değil, sürecin sistemdeki amacı ve davranışıyla uyumlu olup olmadığını belirlemektir. Şüpheli bir süreç tespit edildiğinde PID, PPID, kullanıcı, dosya yolu ve kaynak kullanımı gibi bilgiler incelenerek neden çalıştığı araştırılır.

Sistem Sıkılaştırma ve Lab Denetimi

Sistem sıkılaştırma, bir sistemin gereksiz yetki, servis ve erişimlerden arındırılarak saldırı yüzeyinin azaltılmasıdır. Temel prensipleri arasında en az yetki, gereksiz servislerin kapatılması, hesap ve parola yönetimi, güncellemelerin uygulanması ve gereksiz açık portların kapatılması bulunur.

Lab Ubuntu makinesinde yapılan kontrolde vboxuser hesabının (ALL : ALL) ALL sudo yetkisine sahip olduğu görüldü. Bu yetki lab için kullanılabilir olsa da en az yetki ilkesi açısından geniş bir yetkidir. Sistemde Nginx, web sunucusu olarak kullanıldığı için gerekli bir servis ve TCP/80 açık olması beklenen bir durumdur. CUPS, Avahi ve ModemManager gibi bazı servislerin ise lab amacı açısından gerekli olup olmadığı değerlendirilmelidir. ss -tuln çıktısında 631 ve DNS servislerinin localhost üzerinde dinlediği, 5353/UDP'nin ise Avahi ile ilişkili olduğu değerlendirildi.

Analist açısından; amaç sistemdeki her servisi veya portu kapatmak değil, sistemin amacı doğrultusunda gerekli olanları belirlemek ve gereksiz yetki, servis ve erişimleri tespit ederek saldırı yüzeyini azaltmaktır.